

PENETRATION TESTING FUNDAMENTALS

Types of Penetration Testing

Penetration Testing

Also called **pen testing**, goes a step ahead of vulnerability scanning in security assessment. Unlike vulnerability scanning, which examines the security of individual computers, network devices, or applications, penetration testing evaluates the overall security model of the network.

Penetration testing can reveal the potential consequences of a real attacker breaking into the accounts of network-to-network administrators, IT managers, and executives. It also sheds light on the security weaknesses missed in typical vulnerability scanning.

This is a type of security testing that evaluates an organization's ability to protect its infrastructure, such as network, applications, systems, and users, from external as well as internal threats. It is an effective way of determining the efficacy of the organization's security policies, controls, and technologies. During a penetration test, security measures are actively analyzed for design weaknesses, technical flaws, and vulnerabilities. The test results are documented and delivered in a comprehensive report to executive management and technical audiences.

Types of Penetration Testing

Penetration assessment can be performed using the following approaches:

Goal-Oriented/Objective-Oriented Penetration Testing Approach:

Goals are the drivers for this penetration testing approach. In this type of assessment, a pen tester tasked with identifying or demonstrating a risk attempts to achieve a goal, rather than find vulnerabilities. They focus on finding different ways to achieve the goal. In a goal-oriented penetration assessment, the goal is defined before the start of pen testing. To achieve the set goals (objective), the pen tester performs multiple serial or parallel processes. Some common goals in goal-oriented/objective-oriented penetration testing are as follows:

- Gain remote access to an internal network
- Gain access to credit-card information
- Gain domain administrator access
- Create a denial of service (DoS) condition against a website
- Deface a website

Compliance-Oriented Penetration Testing Approach:

Compliance requirements are the drivers for this approach. It entails testing against adherence to compliance requirements. It involves conducting assessments against the compliance requirements of cybersecurity standards, frameworks, laws, acts, etc.

For example, an organization may ask to perform a security assessment against compliance standards such as PCI-DSS, ISO-27001, FISMA, HIPAA, and HITRUST. Compliance-oriented penetration testing also reviews firewall rules for compliance.

The compliance-oriented penetration testing approach is a proactive approach to secure and maintain compliance. This enables organizations to do the following:

- Maintain the security posture of the organization by identifying and preventing attacks before they occur
- Enhance the security infrastructure or policy framework

- Evaluate an organization's compliance level in specific areas such as patch management, password policy, and configuration management
- Protect client data from breaches, which could result in a heavy penalty
- Verify the system's security with respect to certification and accreditation (C&A) activities

Red-Team-Oriented Penetration Testing Approach:

This approach is an adversarial goal-based assessment in which the pen tester must mimic a real attacker and target an environment. This approach has no specific driver. For example, an organization may ask to conduct a security assessment to evaluate its overall security. It may be included in the evaluation of people, networks, applications, physical security, etc.

Furthermore, it is an offensive type of security testing in which a red team works with a blue team and updates the blue team with the tactics, techniques, and procedures (TTPs) used by the red team.

It enables organizations to do the following:

- Understand their ability to detect and respond to real-world attacks
- Assess their organizational security with respect to specific targets
- Verify their organizational response to an attack
- Validate elements of organizational security postures
- Identify risks missed by the penetration testing team

Strategies of Penetration Testing

Each test type takes a different approach for assessing the security of an organization's infrastructure.

Black-box Testing

To simulate real-world attacks and minimize false positives, penetration testers can choose to undertake black-box testing (or zero-knowledge attack, with no information or assistance from the client) and map the network while enumerating services, shared file systems, and operating systems (OS) discreetly.

White-box Testing

If the organization needs to assess its security against a specific kind of attack or a particular target, complete information about the same may be given to pen testers. The information provided can include network topology documents, asset inventory, and valuation information. An organization typically opts for white-box testing when it requires a complete audit of its security. Regardless, it is critical to note that information security is an ongoing process, and penetration testing only provides a snapshot of the security posture of an organization at any given point in time.

Gray-box Testing

Gray-box penetration testing, the most common approach toward application security, tests the vulnerabilities that an attacker can find and exploit. This testing process functions like black-box testing. Both the attacking team and a normal user of the application are provided with the same privileges, and the purpose is to simulate an attack performed by a malicious insider.

Phases of Penetration Testing

Phases of Penetration Testing

There are three (3) phases in penetration testing: the pre-attack, attack, and post-attack phases.

Pre-attack Phase

This phase focuses on gathering as much information as possible about the target. Information can be gathered invasively through, for example, passive and active reconnaissance, port scanning, service scanning, and OS scanning, or it can be collected noninvasively by, for example, reviewing public records.

Beginning with passive and active reconnaissance, the tester gathers as much information as possible about the target company. Most leaked information is related to the network topology and types of services running within. The tester can use this information to provisionally map out the network for planning a more coordinated attack strategy.

Passive reconnaissance involves the following:

- Mapping the directory structure of the web servers and FTP servers.
- Gathering competitive intelligence.
- Determining the value of infrastructure interfacing with the web.
- Retrieving network registration information from WHOIS databases and financial websites.
- Determining the product range and service offerings of the target company that are available online or can be requested offline.
- Document sifting, which refers to gathering information solely from published material.
- Social engineering can be performed by identifying a conduit (a person who can be targeted easily based on the information gained about personnel) and profiling them.

Attack Phase

The information gathered in the pre-attack phase forms the basis of the attack strategy. During the attack phase, the attack strategy is developed and executed. This phase involves the actual compromise of the target. The tester may exploit a vulnerability discovered during the pre-attack phase or use security loopholes, such as a weak security policy, to gain access to the system.

The important point here is that while the tester needs only one poor entry, organizations must defend several. Once inside, the tester may escalate their privileges, install a backdoor to sustain access to the system, and exploit it to achieve their goal.

Post-attack Phase

The post-attack phase is a crucial part of the testing process, as the tester needs to restore the network to its original state. This involves cleaning up testing processes, removing created vulnerabilities (not those that existed originally), crafting exploits, and so on, until all systems tested are returned to their pre-testing states.

The objective of the test is to show where security fails. Unless there is a scaling of the penetration test agreement, whereby the tester is assigned the responsibility to correct the security posture of the systems, this phase completes the process of penetration testing.

Activities in this phase include (but are not restricted to) the following:

- Reversing all file and setting manipulations performed during the test
- Reversing all changes to privileges and user settings
- Mapping of the network state
- Documenting and capturing all logs registered during the test

It is important that the penetration tester documents all their activities and records all observations and results so that the test can be repeated and verified for the given security posture of the organization. For the organization to quantify the security risk in business terms, it is essential that the tester identifies the critical systems and critical resources and maps the threat to these.

Penetration Testing Methodologies

The cornerstone of a successful penetration test is the methodology involved in devising it. The underlying methodology should help the tester by providing a systematic approach to the testing pattern. The test must satisfy adjectives such as consistency, accuracy, and efficiency, and the testing methodology should be adequate. This does not mean that the entire framework should be restrictive.

The two (2) types of penetration testing methodologies are as follows:

Proprietary Methodologies

Many organizations work on penetration testing and offer services and certifications. Network security organizations have their own methodologies that are to be kept confidential. The following are some proprietary methodologies:

- EC-Council's Licensed Penetration Tester (LPT)
- IBM
- ISS
- McAfee Foundstone

Open-source and Public Methodologies

A wide range of methodologies that are publicly available. They can be used by anybody and are intended for public use only.

- **Open-Source Security Testing Methodology Manual:** This was compiled by Pete Herzog. It is a standard set for penetration testing to achieve security metrics. It is considered the de facto highest level of testing, and it ensures high consistency and remarkable accuracy.
- **Information Systems Security Assessment Framework:** This evaluates an organization's information security processes and policies.
- **National Institute of Standards and Technology (NIST):** A federal technology agency that works with the industry to develop and apply technology, measurements, and standards.
- **Open Web Application Security Project:** An open-source methodology. It provides a set of tools and a knowledge base, which help in protecting web applications and services. It is beneficial for system architects, vendors, developers, security professionals, and consumers who might work on designing, developing, deploying, and testing the security of web servers and web applications.
- **CREST:** The not-for-profit accreditation and certification body representing the technical information security industry. CREST is internationally recognized and provides accreditation for organizations and individuals providing penetration testing, incident response, and threat intelligence services.

Guidelines and Recommendations for Penetration Testing

Characteristics of a Good Penetration Test

Before performing any pen test in an organization, the tester must follow some steps to ensure success.

First, the organization must call for a meeting, in which they must discuss the scope and objectives of the penetration test and the parties involved in it. The objectives of the penetration test must be clear; if the purpose is unclear, then the results will inevitably be inaccurate.

Next, the systems, machines, network, staff involved, and operational requirements are identified to perform the penetration test.

Another important agenda is the time and duration of the penetration test; these factors should be decided in such a manner that the daily operations and normal business of the organization will not be disturbed. Therefore, the organization must ensure that the penetration test is conducted at a particular time of the day because, at times, penetration testing can lead to unusual network traffic, which may cause some systems on the network to crash and affect other working systems on the network. To overcome such situations, the organization must draw a clear plan before proceeding.

The following are a few more points on the characteristics of a good penetration test:

- Establishing the parameters of the penetration test, such as objectives, limitations, and justification of procedures
- Hiring skilled and experienced professionals to perform the test
- Choosing a suitable set of tests that balances cost and benefits
- Following a methodology with proper planning and documentation
- Documenting the result carefully and making it comprehensible for the client

Ethics of a Penetration Tester

Every penetration tester must have ethics that help them avoid illegal activities and serve their clients in a better way. Most organizations make the tester sign an agreement to clarify the current laws and protect their clients. The rules can differ from country to country. Therefore, a penetration tester needs to be aware of the current regulations and legal agreements with an organization, and the tester must be highly ethical and fully professional at all times.

The following are some of the ethical requirements of a penetration tester:

- Perform penetration testing with the express written permission of the client
- Work according to the nondisclosure and liability clauses of a contract
- Test tools in an isolated laboratory prior to an actual penetration test
- Inform the client about any possible risks that might emanate from the tests
- Notify the client at the first discovery of any highly vulnerable flaws
- Deliver social engineering test results only in a summarized and statistical format
- Try to maintain a degree of separation between the criminal hacker and the security professional

Responsibilities of a Penetration Tester

Companies mainly hire penetration testers to understand whether any part of their infrastructure or network is vulnerable to attacks and determines the existence of security holes that a hacker can easily exploit.

A penetration tester must therefore run several tests and prepare an assessment report detailing the tests and their results. Often, the tester runs predefined types of tests and designs their own tests as well to exploit vulnerabilities; to design a custom test, the tester requires a lot of creativity and imagination with a high level of technical knowledge.

In addition, a penetration tester has the following responsibilities:

- Perform the penetration testing and risk assessment of the target system
- Clearly define the goals of the penetration test, ensure superior quality, and effectively communicate the results
- Exploit system vulnerabilities and justify the found vulnerabilities
- Present reports to superiors on the efficiency of the tests and risk assessments, as well as proposals for risk mitigation
- Understand the security of the organization's servers, network systems, and firewalls relevant to specific business risks
- Create and design new penetration tools for testing vulnerabilities
- Identify the methods and techniques that an attacker could use to exploit weaknesses and logic flaws
- Perform social engineering to discover poor password policies or user security practices in an organization
- Conduct physical security assessments of servers, systems, and network devices
- Investigate web applications, client applications, and standard applications for any vulnerabilities
- Include all business considerations, such as loss due to downtime and the cost of engagement in security strategies
- Review and define requirements for information security solutions
- Provide feedback, which is very important for the organization to fix security issues

Reference:

EC-Council. (2021). *Ethical hacking essentials* (1st ed.). EC-Council.